

Tab 1

Botium Toys: Scope, goals, and risk assessment report

Scope and goals of the audit

Scope: The scope of this audit is defined as the entire security program at Botium Toys. This includes their assets like employee equipment and devices, their internal network, and their systems. You will need to review the assets Botium Toys has and the controls and compliance practices they have in place.

Goals: Assess existing assets and complete the controls and compliance checklist to determine which controls and compliance best practices that need to be implemented to improve Botium Toys' security posture.

Current assets

Assets managed by the IT Department include:

- On-premises equipment for in-office business needs
- Employee equipment: end-user devices (desktops/laptops, smartphones), remote workstations, headsets, cables, keyboards, mice, docking stations, surveillance cameras, etc.
- Storefront products available for retail sale on site and online; stored in the company's adjoining warehouse
- Management of systems, software, and services: accounting, telecommunication, database, security, ecommerce, and inventory management
- Internet access
- Internal network
- Data retention and storage
- Legacy system maintenance: end-of-life systems that require human monitoring

Risk assessment

Risk description

Currently, there is inadequate management of assets. Additionally, Botium Toys does not have all of the proper controls in place and may not be fully compliant with U.S. and international regulations and standards.

Control best practices

The first of the five functions of the NIST CSF is Identify. Botium Toys will need to dedicate resources to identify assets so they can appropriately manage them. Additionally, they will need to classify existing assets and determine the impact of the loss of existing assets, including systems, on business continuity.

Risk score

On a scale of 1 to 10, the risk score is 8, which is fairly high. This is due to a lack of controls and adherence to compliance best practices.

Additional comments

The potential impact from the loss of an asset is rated as medium, because the IT department does not know which assets would be at risk. The risk to assets or fines from governing bodies is high because Botium Toys does not have all of the necessary controls in place and is not fully adhering to best practices related to compliance regulations that keep critical data private/secure. Review the following bullet points for specific details:

- Currently, all Botium Toys employees have access to internally stored data and may be able to access cardholder data and customers' PII/SPII.
- Encryption is not currently used to ensure confidentiality of customers' credit card information that is accepted, processed, transmitted, and stored locally in the company's internal database.
- Access controls pertaining to least privilege and separation of duties have not been implemented.
- The IT department has ensured availability and integrated controls to ensure data integrity.
- The IT department has a firewall that blocks traffic based on an appropriately defined set of security rules.
- Antivirus software is installed and monitored regularly by the IT department.

- The IT department has not installed an intrusion detection system (IDS).
- There are no disaster recovery plans currently in place, and the company does not have backups of critical data.
- The IT department has established a plan to notify E.U. customers within 72 hours if there is a security breach. Additionally, privacy policies, procedures, and processes have been developed and are enforced among IT department members/other employees, to properly document and maintain data.
- Although a password policy exists, its requirements are nominal and not in line with current minimum password complexity requirements (e.g., at least eight characters, a combination of letters and at least one number; special characters).
- There is no centralized password management system that enforces the password policy's minimum requirements, which sometimes affects productivity when employees/vendors submit a ticket to the IT department to recover or reset a password.
- While legacy systems are monitored and maintained, there is no regular schedule in place for these tasks and intervention methods are unclear.
- The store's physical location, which includes Botium Toys' main offices, store front, and warehouse of products, has sufficient locks, up-to-date closed-circuit television (CCTV) surveillance, as well as functioning fire detection and prevention systems.

Tab 2

Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each control, including the type and purpose, refer to the [control categories](#) document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☒	☐	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☒	☐	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance

- ☒ ☐ Fire detection/prevention (fire alarm, sprinkler system, etc.)

To complete the compliance checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each compliance regulation, review the [controls, frameworks, and compliance](#) reading.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers’ credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers’ data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.

- | | | |
|--------------------------|-------------------------------------|---|
| ☐ | ☒ | Enforce privacy policies, procedures, and processes to properly document and maintain data. |
|--------------------------|-------------------------------------|---|

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☒	☐	Data is available to individuals authorized to access it.

This section is *optional* and can be used to provide a summary of recommendations to the IT manager regarding which controls and/or compliance best practices Botium Toys needs to implement, based on the risk posed if not implemented in a timely manner.

Recommendations (optional): In this section, provide recommendations, related to controls and/or compliance needs, that your IT manager could communicate to stakeholders to reduce risks to assets and improve Botium Toys' security posture.

SECURITY AUDIT RECOMMENDATIONS Botium Toys — Internal Security Assessment

Overview

Following the completion of the internal security audit conducted against established controls and compliance frameworks, the following recommendations have been identified. These findings are presented to guide the organization in strengthening its security posture, protecting customer data, and ensuring continued regulatory compliance.

1. Access Control & Least Privilege

The organization currently lacks implemented Access Control Lists (ACLs). It is strongly recommended that access controls be established in alignment with the principles of least privilege and separation of duties. Each employee should be granted access only to the systems and data necessary to perform their specific job functions. No single employee should hold excessive privileges across multiple systems. This will significantly reduce the risk of insider threats and, in the event of a network breach, will limit an attacker's lateral movement and overall access to sensitive resources.

2. Encryption

Customer data, including Personally Identifiable Information (PII) and Sensitive Personally Identifiable Information (SPII), is currently unencrypted despite being accessible within the system. It is recommended that encryption be immediately implemented for all data at rest and in transit. This will protect customer data from identity theft and unauthorized access, ensuring that even if data is intercepted, it remains unreadable to malicious actors.

3. Intrusion Detection System (IDS)

The organization does not currently have an active Intrusion Detection System in place. It is strongly recommended that an IDS be deployed and configured to monitor network traffic continuously, detect suspicious activity, and generate alerts when potential incidents are identified. Early detection is critical to minimizing the impact of security incidents and enabling a timely response.

4. Disaster Recovery Plan

No formal Disaster Recovery Plan (DRP) currently exists within the organization. A comprehensive DRP should be developed, documented, and tested to ensure business continuity in the event of a data breach, system failure, or other disruptive incident. The plan should clearly define recovery objectives, assign roles and responsibilities, and outline step-by-step procedures for restoring operations. Without this, the organization remains critically vulnerable to prolonged downtime and data loss following any major incident.

5. Password Policy & Centralized Password Management

While a password policy exists, it does not meet current industry standards. It is recommended that the policy be updated to enforce strong password requirements including a minimum character length, use of uppercase and lowercase letters, numbers, and special characters. Additionally, a centralized password management system should be implemented to provide employees and vendors with a secure, monitored, and reliable method of credential management. This reduces the risk of weak or reused passwords compromising organizational systems.

6. Legacy Systems Management

Legacy systems are currently active and monitored; however, no formal maintenance schedule exists and intervention methods remain undefined. It is recommended that a regular maintenance schedule be established for all legacy systems, with clearly documented

intervention procedures. This ensures that vulnerabilities within older systems are identified and addressed promptly, reducing the organization's overall attack surface.

7. Strengths to Maintain

The following controls were found to be functioning effectively and should be continuously maintained:

Firewall — active and properly configured

Antivirus software — active and operational

Physical security controls — up to date

EU regulatory compliance — breach notification procedures aligned with the 72-hour GDPR requirement.

Conclusion:

The organization demonstrates a foundational commitment to security through its active firewall, antivirus, and physical controls. However, the gaps identified above represent significant risks to the confidentiality, integrity, and availability of customer data. Full implementation of these recommendations will substantially strengthen the organization's security posture, ensure regulatory compliance, protect customer trust, and position the company for sustainable and secure operations going forward.